



only_api_no_web_user_auth

Site: <https://localhost:8443>

Generated on Sat, 2 May 2026 09:52:01

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	4
Informational	2

Insights

Level	Reason	Site	Description	Statistic
Low	Exceeded High	https://localhost:8443	Percentage of responses with status code 4xx	79 %
Info	Informational	http://localhost:8443	Percentage of responses with status code 4xx	100 %
Info	Informational	https://ajax.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://ajax.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %

Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of slow responses	48 %
Info	Informational	https://localhost:8443	Percentage of responses with status code 2xx	8 %
Info	Exceeded Low	https://localhost:8443	Percentage of responses with status code 5xx	12 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type application/json	5 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/html	94 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method DELETE	23 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method PATCH	35 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method POST	5 %

Info	Informational	https://localhost:8443	Percentage of endpoints with method PUT	35 %
Info	Informational	https://localhost:8443	Count of total endpoints	17
Info	Exceeded Low	https://localhost:8443	Percentage of slow responses	20 %
Info	Informational	https://use.fontawesome.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://use.fontawesome.com	Percentage of slow responses	96 %

Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	Systemic
Buffer Overflow	Medium	8
Application Error Disclosure	Low	2
Cookie Without Secure Flag	Low	2
Information Disclosure - Debug Error Messages	Low	2
Strict-Transport-Security Header Not Set	Low	Systemic
Authentication Request Identified	Informational	3
Session Management Response Identified	Informational	1

Alert Detail

Medium	Absence of Anti-CSRF Tokens
Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL /form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site.

	CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.
URL	https://localhost:8443/api/v1/users/me
Node Name	https://localhost:8443/api/v1/users/me
Method	DELETE
Attack	
Evidence	<form action="/logout" method="post">
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: ""].
URL	https://localhost:8443/api/v1/users/me
Node Name	https://localhost:8443/api/v1/users/me
Method	GET
Attack	
Evidence	<form action="/logout" method="post">
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: ""].
URL	https://localhost:8443/api/v1/users/me/password
Node Name	https://localhost:8443/api/v1/users/me/password ()({oldPassword,newPassword, confirmPassword})
Method	PUT
Attack	
Evidence	<form action="/logout" method="post">
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: ""].
Instances	Systemic
Solution	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).
	Note that this can be bypassed using XSS.

	Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html
CWE Id	352
WASC Id	9
Plugin Id	10202

Medium	Buffer Overflow
Description	Buffer overflow errors are characterized by the overwriting of memory spaces of the background
URL	https://localhost:8443/api/v1/tours
Node Name	https://localhost:8443/api/v1/tours ()(multipart:name,description,price,duration,numPeople,hotell
Method	POST
Attack	NdNJwksAlwqBsUCyVOrQLYDvDoYgqnYeMsXopTZmMbfCpsWqPTGqjxmyBeCDtPtcBJJRLF
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/tours
Node Name	https://localhost:8443/api/v1/tours ()(multipart:name,description,price,duration,numPeople,hotell
Method	POST
Attack	eKKNJpEjLkaZJjZdZsVAeOKIKgtaBmfdwllfSsGihbUsbySlwYqllhokroPVSaTXMIxYEZGcvhhaq
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/users/register
Node Name	https://localhost:8443/api/v1/users/register ()(multipart:userData,imageFile)
Method	POST
Attack	QOvtgtUpVOcKaJnIJjRowPyFmwDmncxJABQWouDQyWEDEUsRyidwfTvmvhrTePIHpbvXDgf
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/users/register

Node Name	https://localhost:8443/api/v1/users/register ()(multipart:userData,imageFile)
Method	POST
Attack	RGqcFixnGRKDXvNMjkJhTglkyZWCgiHoXWZPomvUGvxKGYhCnJnaSDvBYGKTEsVBYsWF3
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/users/register
Node Name	https://localhost:8443/api/v1/users/register ()(multipart:userData,imageFile)
Method	POST
Attack	ZJvjbpmLWmCPhOSNKdgqyCallamoadeiPxajBGfnnlhXrWLEOhpiLYFYuAjuIWDhKatfPPjBMJ
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/users/register
Node Name	https://localhost:8443/api/v1/users/register ()(multipart:userData,imageFile)
Method	POST
Attack	mHvNXSGydtUxZdLyocNhBkcRVmYkuEFaCkfrjRDnlqexFIPmjSiEvQJPbRdyLJuhgLWVEHLd
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/tours/
Node Name	https://localhost:8443/api/v1/tours/ ()(multipart:name,description,price,duration,numPeople,hotel
Method	PUT
Attack	XCQcjxxJFgdJFpemBAeviNYkiidxbGaQEEfuHKvDoYQvyRqrvGLOjJvGmRnKNFPvIkSDvdCKo
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/api/v1/tours/
Node Name	https://localhost:8443/api/v1/tours/ ()(multipart:name,description,price,duration,numPeople,hotel
Method	PUT
Attack	rDLKZEfFHwPFAfpWTfiQVqkPgTNmTuorfdWjbtqtNVeQCblgGLPEGWulcwwDNmLPOlpEuAHf
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
Instances	8
Solution	Rewrite the background program using proper return length checking. This will require a recom
Reference	https://owasp.org/www-community/attacks/Buffer_overflow_attack
CWE Id	120
WASC Id	7
Plugin Id	30001

Low	Application Error Disclosure
Description	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
URL	https://localhost:8443/api/v1/images/
Node Name	https://localhost:8443/api/v1/images/
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/api/v1/tours/
Node Name	https://localhost:8443/api/v1/tours/
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
Instances	2
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low	Cookie Without Secure Flag
Description	A cookie has been set without the secure flag, which means that the cookie can be accessed via unencrypted connections.
URL	https://localhost:8443/api/v1/auth/login
Node Name	https://localhost:8443/api/v1/auth/login ()({username,password})
Method	POST
Attack	
Evidence	Set-Cookie: AuthToken
Other Info	
URL	https://localhost:8443/api/v1/auth/login
Node Name	https://localhost:8443/api/v1/auth/login ()({username,password})
Method	POST
Attack	
Evidence	Set-Cookie: RefreshToken

Other Info	
Instances	2
Solution	Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html
CWE Id	614
WASC Id	13
Plugin Id	10011

Low	Information Disclosure - Debug Error Messages
Description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.
URL	https://localhost:8443/api/v1/images/
Node Name	https://localhost:8443/api/v1/images/
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/api/v1/tours/
Node Name	https://localhost:8443/api/v1/tours/
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
Instances	2
Solution	Disable debugging messages before pushing to production.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://localhost:8443/api/v1/tours//image/media
Node Name	https://localhost:8443/api/v1/tours//image/media
Method	GET

Attack	
Evidence	
Other Info	
URL	https://localhost:8443/api/v1/tours/image/media
Node Name	https://localhost:8443/api/v1/tours/image/media ()({imageFile})
Method	PUT
Attack	
Evidence	
Other Info	
URL	https://localhost:8443/api/v1/users/image
Node Name	https://localhost:8443/api/v1/users/image ()({imageFile})
Method	PUT
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	https://localhost:8443/api/v1/users
Node Name	https://localhost:8443/api/v1/users ()({name,lastName,email,password,mainPhone,secondaryPhone,enabled,moneySpent,roles})
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password
URL	https://localhost:8443/api/v1/users/
Node Name	https://localhost:8443/api/v1/users/ ()({name,lastName,email,password,mainPhone,secondaryPhone,enabled,moneySpent,roles})

Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password
URL	https://localhost:8443/api/v1/auth/login
Node Name	https://localhost:8443/api/v1/auth/login ()({username,password})
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=luis@email.com passwordParam=password
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://localhost:8443/api/v1/auth/login
Node Name	https://localhost:8443/api/v1/auth/login ()({username,password})
Method	POST
Attack	
Evidence	AuthToken
Other Info	cookie:AuthToken cookie:RefreshToken
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112